6

INTRO TO PASTA

RISK-CENTRIC THREAT MODELING

"Risk comes from not knowing what you are doing."

Warren Buffet, Billionaire, Philanthropist, Investor

Understanding and exercising a broad scope of real-world attack patterns better depict the viability of threats. Combined with a risk-centric approach that centers on developing countermeasures commensurate to the value of the assets being protected, PASTA (Process for Attack Simulation and Threat Analysis) allows for a linear threat model to achieve both technical sophistication and accuracy and a marketable message around risk mitigation strategy. This can be achieved by realizing three key attributes as part of its methodology: topicality, substantiation, and probabilistic analysis. These attributes will be exemplified in the step-by-step coverage of the PASTA methodology in this chapter.

For any security process to be successful, it needs to be repeatable, measurable, yield results, and invite more stakeholders than those found in security and compliance. The risk-centric threat model detailed in this chapter provides a linear methodology to encompass all of these aforementioned characteristics. Its multistep process is combined with a multifaceted focus to various stakeholders. In lieu of IT, information security, and business groups maintaining disaccord over security deliverables, a risk-centric threat modeling approach unifies disparate goals over a linear workflow

Risk Centric Threat Modeling: Process for Attack Simulation and Threat Analysis, First Edition.
Tony UcedaVélez and Marco M. Morana.
© 2015 John Wiley & Sons, Inc. Published 2015 by John Wiley & Sons, Inc.

that is comprehensive yet simple to use. Aspects of this methodology have already been introduced; however, this chapter focuses further into each of the steps in PASTA so that readers can consider how each stage events' can be applied within their own environments. As previously mentioned, PASTA's approach is asset or risk centric; therefore, the following chapter will be focused solely on this approach and provide points for why this approach may be of best value over some of the software-centric threat modeling alternatives that exist.

Inherent Challenges to Threat Modeling

Some of the inherent challenges to threat modeling center around company culture, resources, maturity of process and control, and most importantly executive support. Lack of executive support truly nullifies even contemplating threat modeling for an organization. Beyond this, the other inherent challenges become more easily overcome, however, nonetheless a challenge. Next would have to be the company culture. If there is a lot of corporate politics that are centered on self-preservation or subscribing to the *blame-game*, this may thwart threat modeling before it ever gets into a beta phase. Tool dependency or the lack of any tools will also weaken any threat modeling methodology, although with far less impact as the lack of executive sponsorship. Conversely the lack of any tools for application testing will limit the sophistication of the application threat model.

Process maturity can be an inherent challenge as well since several inputs and outputs of the threat modeling methodology are dependent on somewhat established processes such as incident management, security governance, risk management, vulnerability management, system imaging, pen testing, project management source code reviews, asset management and more. Still not detrimental to overall threat modeling adoption and ongoing execution, immature processes can force the use of maturity models in order to track which threat modeling activities are initially performed and how they are refined over time. Those reading should not be discouraged to think that threat modeling adoption should only come at a time when all security and technology processes are running at a CMMI level 5. Most places are running in the low CMMI 3 levels and are quite able to adopt threat modeling initiatives while receiving benefiting from the various benefits that threat modeling provides outside of each stage's deliverables.

Again, threat modeling via PASTA is possible in nearly all scenarios except for when there is no executive sponsorship of its process and produced artifacts. The reason for this is that the deliverables produced by the PASTA approach are intended to be also socialized with senior executives.

Threat Modeling Methodologies: A Quick Comparative Look

A quick reminder that the application threat modeling that will be depicted in this chapter will revolve around a risk-centric approach. Nothing is actually lost in terms of steps, terminology, or even artifacts produced, it is just that PASTA prefaces many of the same activities around DFDs, building attack trees, threat enumeration, with

some valuable context that makes that overall threat analysis to much more sophisticated than simply finding security weaknesses or application development inefficiencies, but discovering all of the aforementioned with the proper context and applying security commensurate to the subject application's importance to the organization. Security- or software-centric approaches to threat modeling cannot derive risk values *to the degree* that an asset- or risk-based methodology can deliver. Our desire to focus on a risk-based approach stems from the key principle that risk ultimately needs to be elevated back to the business; regardless of technical, security, or nonintrinsic business characteristics, risk needs to be effectively mapped, socialized, and accepted by information owners from the business unit that governs the application or system environment. Ultimately, technologists need to recognize that sponsorship of any software/system development life cycle or security program within an organization is in support of the business and its objectives. Software-centric or security-centric objectives that translate and elevate technical risk findings to only a developer, engineer, or manager will, in essence, not effectively communicate risk beyond that of a technical nature.

Before Starting Prior to diving into the application threat modeling methodology, we will address some planning prerequisites that have come from applying PASTA in large-size and mid-size enterprises. These prerequisites will help to organize the people, processes, technology, and third-party groups that carry an integral role in the PASTA framework.

As with any process function, readiness may be as just as important as execution. Figure 6.1 provides a brief but important checklist to review prior to adopting and executing the proposed PASTA threat modeling methodology. This checklist forces an organization to address key questions during each of the phases as they will greatly impact the success when considering adoption and use of threat modeling techniques as reflected by the PASTA methodology.

Sponsorship and Support

If you have been to a security conference of any type, from BlackHat to RSA, the message of obtaining executive sponsorship for security efforts is timeless. The message bears repeating: if you are going to launch an effective, repeatable threat modeling process within your organization of any size, you had better make sure that you have senior management's support and understanding. In order to make this less of a pain to sell, individuals will want to hone in on the following value points:

1. Threat modeling via PASTA allows greater cohesiveness among security groups in operations, governance, architecture, and development.
2. PASTA allows money and time savings by incorporating security governance at the inception of development efforts, thereby reducing compliance gaps, audit findings, and risk issues – all that warrant remediation management and exception or waiver management workflows.

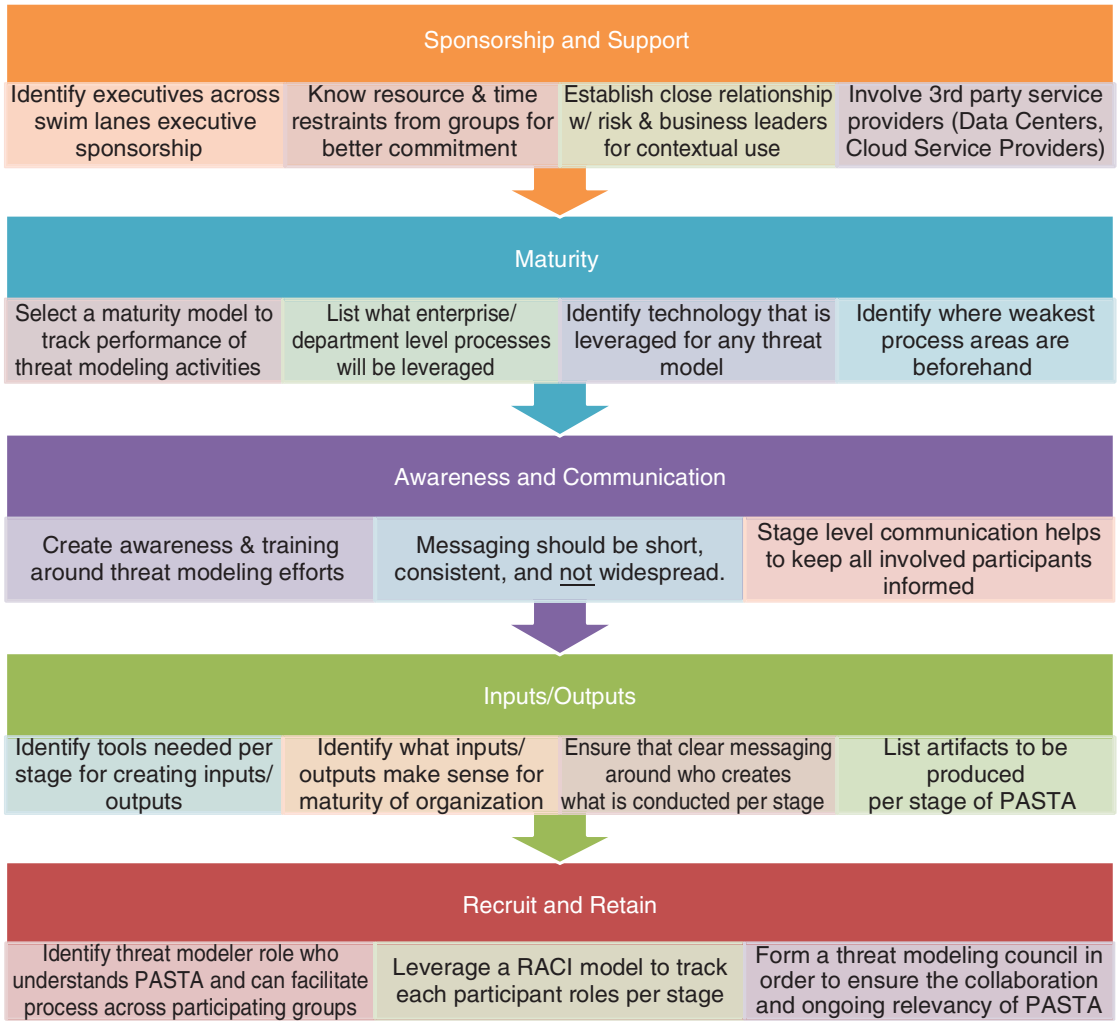


Figure 6.1 Impacting Factors Across PASTA: A Checklist for Success

3. Threat modeling with PASTA will foster greater understanding of likely attack sources. Current efforts may simply take prefabricated attack scripts from security solutions without truly understanding how those attacks are really addressing security weaknesses in their software or vendor software. If a company is serious about security and mitigating the advanced threats that continuously approach, a shift in approach and technique is warranted.
4. PASTA takes security principles to both business and IT groups as part of their normal workflow of the SDLC process, thereby introducing a type of security on-the-job training that serves as an effective awareness vehicle. Developers, QA, Network Engineers, and System Administrators are now better able to understand specifically how inaction in corrective security measures can introduce risks to the application and the data it manages.
5. PASTA makes things less adversarial in terms of addressing security risk mitigation. It is no longer an "us" versus "them" mentality. More collaborative, more warm, and fuzzy – overall, an HR love story in the making.

Culture, time, and availability of human resources and tools will obviously be a large determinant as to whether or not threat modeling of any flavor is adopted. Having consulted on the topic to a large and disparate population of companies and government entities, there is no common profile where threat modeling is well received. Large companies have different vantage points than smaller companies. Larger organizations will have the depth in resources to address some of the stages in PASTA that relate to objective building, security/technology governance, and risk analysis, while smaller organizations are less likely to be organized in those areas. They, however, will be more nimble in applying proper application decomposition exercises, threat analysis, and vulnerability/attack mapping than their larger Fortune 500 counterparts. In the end, as with any process, it will take time. During that time, sponsorship is the key as well as measuring the execution PASTA over time. Metrics will ultimately determine how effectively threat modeling serves the selected application environments as well as the overall enterprise.

Maturity

The maturity of processes and controls, leveraged by any threat modeling methodology (i.e. – Architecture, Software Development), will affect the success of PASTA. Immature processes should not negate the adoption of PASTA, but instead force the use of a maturity model in conjunction with the threat modeling methodology. In some cases, immature controls enable application threat modeling to become adopted easier since many of the processes could be developed in support of PASTA as the iterative methodology is carried out. This all depends on the level of resources available as well as the perception and executive support.

Awareness

No process or technology, aimed for the benefit of a wide audience, is successfully carried out or implemented in the shadows without proper communication. In too many instances, security artifacts become shelf-ware because they are developed and executed in a vacuum. For this reason, awareness efforts around threat modeling should take place before, during, and after the threat modeling process. The overall message should be directed to both participants and benefactors of the application threat modeling process. Some may scoff at this idea, but the reality is that the lack of communication in InfoSec has been the downfall of many security efforts. Most often, recipients of the communication around threat modeling efforts will appreciate their inclusion in this effort and be pleased to know that the objective revolves around preserving the business objectives for the application environment. Last, properly communicating application threat modeling procedures will ultimately lead to a greater understanding of what is expected regarding remediation patterns against the application environment.

In the spirit of launching effective awareness efforts around application threat modeling, simplicity and clarity of message is critical. There are many communication efforts that announce InfoSec efforts regularly. The announcement of a new Policy or Standard, changes to Access Control protocols, or implementation of new

identity management software are a few examples that have benefited from centralized and formal communication. Application threat modeling, however, works best with quaint, short, clear messages delivered by the threat modeler. Regardless of approach, the message should be confined to those who will partake in the threat modeling exercises as well as those who will benefit from the varied artifacts and deliverables to be produced.

Clarity around threat modeling's taxonomy of terms or vernacular has been sabotaged by early adopters or security professionals that have distorted many of the definitions and usage. There is an enormous amount of misuse. Status quo security professionals who find themselves seeking to use the latest term or security colloquiums have often equated other security disciplines in security (i.e. - pen testing, static analysis, application risk assessments, etc.) to threat modeling. This exemplifies the need for greater awareness on what is meant by the term and associated terms and use of its vocabulary.

Communication around each PASTA stage needs to be met with clear timeliness and aligned to milestones for each stage of the PASTA threat modeling methodology. Embellishing simple project management principles for awareness efforts will help maintain a fluid communication plan absent of last-minute reminders supporting tasks. For example, last-minute communication of threat modeling efforts may obviously jeopardize the participation of much needed SMEs. With this in mind, timely communication of threat modeling efforts, across various stages of the methodology, will ensure everyone's knowledge on both the upcoming threat modeling process and remediation patterns that are manifested by one or more deliverables.

Inputs/Outputs of the PASTA Process

The ingredients for making great PASTA boil down to people, information sources, and artifacts to be created. They comprise the essential inputs/outputs for an effective threat modeling methodology. This section quickly addresses each, with even further detail to be provided within each phase of the PASTA methodology for threat modeling.

People as Inputs People may be the most important input to consider when embarking on threat modeling efforts for your application environments. Do you have the right people in place? If not, can you leverage your security partners at various stages of the PASTA methodology in order to deliver where you may not be able to internally? These types of questions are important to answer prior to embarking on any application threat model methodology.

Behind any process is a leader or governing group. In this case, application threat modeling does require a figurehead more than a group, as a large number of figureheads can introduce dysfunction when creating a single threat model for an application environment. The threat modeler's primary function is to sustain a holistic oversight of the subject application environment in order to provide a threat model based on realistic and probable attack scenarios that could jeopardize the application environment in question. The threat modeler is well versed across multiple functional

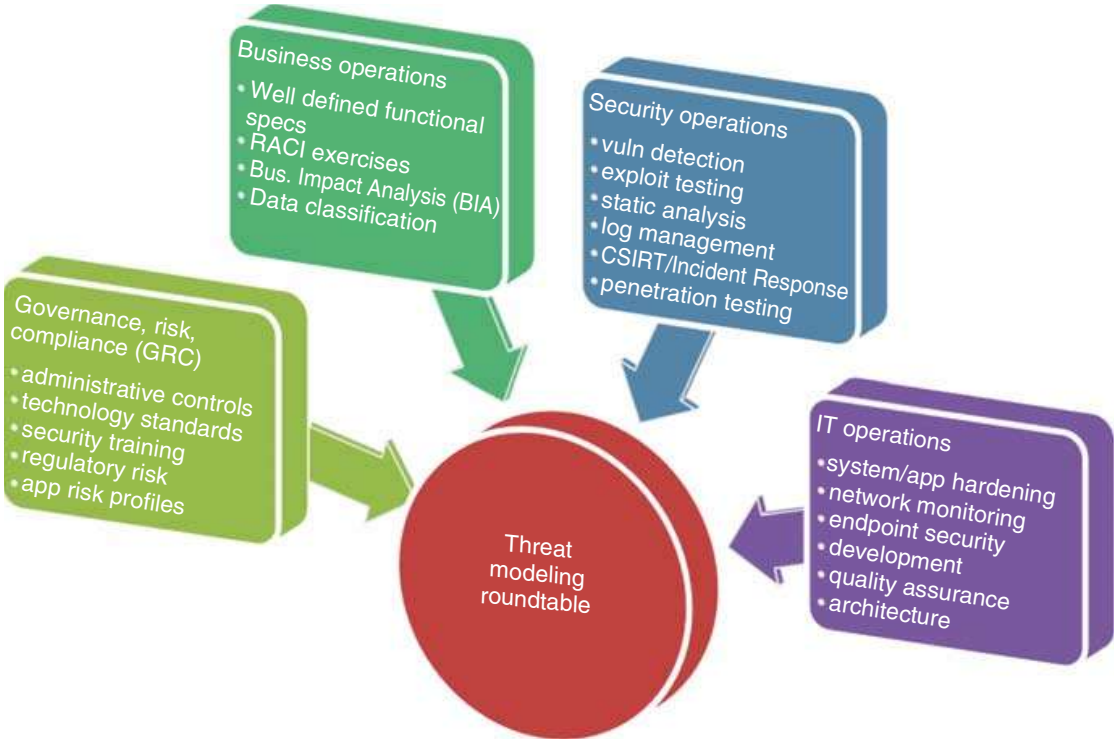


Figure 6.2 Threat Modeling Team Selection

areas in which the application environment operates (development language, system level, networking, client software, mobile technologies) or wherever the application environment extends. The threat modeler may add one or two other individuals to assist during the execution of the threat modeling process, particularly in areas where technical deficiencies may exist. Given that threat modeling encompasses the following organizational layers, it is preferred that the threat modeler seek representation from each one of the areas depicted in Figure 6.2 in order to establish a temporary committee around the threat modeling efforts.

Establishing an ambassador-like representation during the threat modeling process allows greater facilitation and funneling of ideas and feedback received during the threat modeling process. Initially, the participation of such ambassadors will entail a level of familiarity that would need to be established. Representatives from each of these groups will need to be trained mostly on the purpose and understand the ultimate goal of the threat modeling process, based on the overall approach to be used (asset based, software centric, or security centric). Representatives from each of these aforementioned areas will be used and leveraged at varying times of the threat modeling process but must be included on the threat model's development and maturity during the overall process.

The newly formed threat modeling team must be engaged with a strong sense of collaboration. It should be mentioned that the term "team" is used very loosely. It can mean a union of technology, security, and business professionals and does not necessarily have to be a formal process or event. This may seem to bear no mentioning in a security book, but the lack of tact in communication has been a sharp thorn to other security processes and for threat modeling to work, it must adhere to its



Relevant stage(s): stage I, VII
The *business analyst* brokers security information back and forth between the security team and threatmodeling coordinator and is responsible for ensuring that the proper understanding of business risk relevance in maintained throughout each stage of the application threat model. Critically important to the threat model is the BA's ability to understand and convey the number of use cases for the application and provide context .



Relevant stage(s): stage I, VII
The project manager serves as a escalation point and task manager for all of the threat modeling activities.More actively involved as part of the inherent risk discussions in Stage 1 of PASTA, the project manager otherwise remains simply *Informed or Consulted* participant in the overall RACI model. Key role that the PM plays is to ensure that the subscribed tasks for each of the PASTA stages gets completed.



Relevant stage(s): stage I, VII
The business unit manager has the responsibility of becoming aware of the inherent risk and risk profile details that are provided as inputs to the threat modeling PASTA methodology. This role maintains a mostly Informed role as part of the PASTA activities, mostly in order to be aware of the threat model that is being developed, likely attack vectors, and ultimately able to make a risk mitigating decision via application countermeasures when needed.

Figure 6.3 Business Cross Section of a Threat Modeling Team

natural framework for collaboration to take place. Unified by identifying threats and mapping out probabilities and impact, the threat modeling team will ultimately seek risk mitigation for the defined application environment to preserve agreed upon business objectives. As part of this effort, a demographic breakdown of threat modeling participants is depicted in Figure 6.3 (see also Figures 6.4–6.6).

These prior illustrations are only a subset of the various possibilities for a heterogeneous representation of a threat modeling team. Other groups not represented may include key members of third-party diverse representation from each of the four groups. In some cases, an internal pen tester from the Security Ops group may be absent, in which case an alternative member from the group, say a web application security tester, may be brought in for depicting attack patterns under *Stage VI: Attack Tree Modeling*. Obviously, their strengths in identifying attack vectors and misuse cases will surround web-based environments or those that support http/https protocols. As a result, the threat modeler will have to compensate for shortcomings in identifying network-based or even host-based misuse cases or attack patterns. Overall, it is important for the threat modeler to identify where gaps in expertise may exist so that he/she can provide gap-fill level testing to those that would typically be covered by a pen tester. In this scenario, the threat modeler would have to arrange for vulnerability assessments, followed by penetration tests on discovered vulnerabilities for areas in which the web application security specialist would not cover with their level of testing. In doing so, those efforts, combined with the testing efforts performed by the web application security specialist, would reflect greater coverage across multiple levels of the ISO model.[1]

Ideally, the threat modeler will have access to security and IT professionals who have the greatest level of proficiency in niche areas encompassed by the stage of the application threat model (e.g. static analysis for PHP web applications, assessing middleware or web proxies). In the instances where these resources are not available

[1] ISO model encompasses the Physical, Data, Network, Transport, Session, Presentation, Application layer of network architecture.



IT operations



Architect

Relevant stage(s): stage II, III, IV, VII
As a holistic overseer to a given application, the architect plays a pivotal role in application threat modeling by seeing how attack branches of the threat model unfold to reveal viable attack patterns, supportive vulnerabilities, target actors & affected application components. Having a 1,000 foot understanding of the application, the architect is able to see how and where countermeasures are weakest across an application's footprint. Based upon time, effort, and resources, the architect can work with network engineers, developers, and product managers to implement appropriate preventative, detective, and reactive countermeasures that affect access control, validation checks, network ingress/egress, authentication, audit trail, and encryption use.



Developer

Relevant stage(s): stage I, II, III, IV, VII
The developer is one of the key audience member in threat modeling. Across the seven stages, the developer will contribute in various ways. Developers will help to identify application related components, particularly those that are software based (Stage II). During Application Decomposition (Stage III), developers can map data flows among application components from the prior stage, Technology Scoping (Stage II). Where application developers have developed or contribute to existing application log engines, events within such logs can provide for contextual based threat intelligence (Stage IV). Last, developers will ultimately be responsible for application based countermeasures that reduce any level of residual risk identified by the threat model (Stage VII), so their role as an *Informed* player becomes important.



Systems Engineer OR SysAdmin

Relevant stage(s): stage II, III, IV, VII
The systems engineer will be savant to the system/ platform components that are relevant for the application threat model (Stage II). As such, they would also be well positioned to apply hardening techniques at the system level at this stage. The systems engineer would also be helpful in mapping any data flows that interact with the system or database server stack (Stage III), thereby contributing to the Application Decomposition discussion and DFD creation activities. Threat intel may also be needed from in-scope systems, therefore, they play a *Consulted* role under Threat Analysis (Stage IV). Last, countermeasures against the residual risk areas may come from system hardening techniques, therefore, Systems Engineers will be key during this stage.

Figure 6.4 IT Operations Cross Section of a Threat Modeling Team



Network Engineer

Relevant stage(s): stage II, III, IV, VII
Network engineers can identify network assets, protocols, authentication controls, and overall network services that are being allowed across the system environment (Stage II). Within the Technology Scope stage, the network engineer can provide 'blind threat modeling' mitigation via the use of applying network governance standards that could harden the network related infrastructure supporting the application. Network engineers can also assist during the Application Decomposition (Stage III), especially as it relates to threat modeling for administrative use cases and defining network protocol use for APIs. Similarly, their knowledge of network log solutions, particularly those at an enterprise level make the network engineer an important Consulted or even Accountable role under Threat Analysis, (Stage IV). During this stage, the network engineer can help harvest relevant network logs from the scope of network components as well as from any Security Incident Event Monitoring (SEIM) solution. Last, network engineers may be involved under Stage VII in order to apply possible mitigation techniques at the network level.



QA Tester

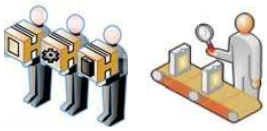
Relevant stage(s): stage I, II, V, VI
The QA tester will play an informed role across multiple stages since their testing requires a comprehensive understanding of the application environment. First, the use cases supported by the application (Stage I) as well as the employed application components (stage II) which may undergo functional testing. Across these two stages, the QA tester serves as an Informed party. Their role can become a bit more involved if their functional testing is also accompanied by security testing. If executing as a security testing entity, the QA Tester can validate the presence of software vulnerabilities and their exploitation levels (Stages V & VI).



Support ops / access control

Relevant stage(s): stage I, II, III, IV
Access Control groups are highly useful during Stages I and II by the fact that they can provide insight to application use cases that related to application support, remote administration, account provisioning/ de-provisioning. Also, under Stage II, Access Control technology components supporting access control functions for the application could be enumerated as part of a list of application countermeasures (e.g. – IdM, AD, ADFS, AD Proxy, LDAP, RADIUS, TACACS+). API calls to these components can be depicted during the Application Decomposition stage and members from these groups would only be suggested to maintain a *Consulted* role. A final stage of critical importance would be the access control violations across all access control logs (network, database, application, middleware, etc.) which would provide valuable threat intelligence in stage IV of the PASTA process.

Figure 6.4 (*Continued*)



Security operations

Security engineers

Relevant stage(s): stage IV, V
Security operation groups fulfill an array of different tasks across an enterprise. One of which is reviewing alerts, logs, and other types of technology related incidents. These functions serve a wealth of information related to threat intelligence. Sourcing this type of data during the Threat Analysis stage of the PASTA methodology can help map security events to threat patterns. Security engineers can substantiate or even dispel evidence surrounding threat scenarios depicted under the Threat Analysis stage. Separate to managing various logging events and alerts, security engineers execute multiple different scan types across an enterprise. Configuration scans, vulnerability scans, source code audits, network discovery scans are just a few types of key scans that lend to producing valuable information for a risk centric threat model. In general, scan results produced by this group provides insight to the nature of vulnerabilities or misconfigurations that affect the application scope of components. Security engineers can perform targeted scans against the scope of application components under the Vulnerability Analysis (Stage V) phase of the PASTA process. The various types of scans will identify initial flaws in the application's security model that can be mapped to the attack tree as a branch to a asset component The supporting attack tree illustrates how identified threats could be viable beginnings of legitimizing threat possibilities.



Pen testing/ App testing team

Relevant stage(s): stage VI
Building from targeted vulnerability scans from Stage V, a pen testing group will look to definitively prove the possibility for exploitation of identified flaws in coding, implementation, configuration, etc. Pen testers may actually be within the same Security Operations group, however, they are often times a third party that may routinely pen test a series of applications for a client organization. Inclusion of pen tests in the threat modeling processes seeks to qualify the viability of exploitation for discovered flaws from Stage V. If vulnerabilities become exploitable, both component weakness and the attack pattern(s) that were able to subjugate them now become relevant factors of residual risk calculations. Even if tested components do not become exploited during a pen test, the result doesn't necessarily mean that the that the overall exploitability of the component is negligible and/or the residual risk calculation is lessened. The use of pen testers as part of the threat modeling process provides an invaluable 'smoking gun' to both developers and architects who may not have understood the manner in which vulnerabilities translated into exploitable risks.

Figure 6.5 Security Operations Cross Section of a Threat Modeling Team



Incident handler

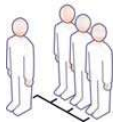
Relevant stage(s): stage IV
Incident response plays a key role in Stage IV: Threat Analysis as IR/CERT teams can provide historical context to historical attacks that correlate to the application environment based on variables such as business type, data type, data worth, accessibility (direct/indirect), user base, black market worth/use of data. Introduces attack profiling capabilities to threat model and supports probability values of risk formula in Stage VII: Risk and Impact Analysis.



Managed security provider

Relevant stage(s): stage IV, V, VI
Managed Security Service vendors or other vendors charged with conducting periodic red team exercises (tactical social engineering, physical intrusion, covert ops exercises for illicit access and data compromise) may be incorporated in the threat analysis for a given application environment in order to identify weak physical/logical controls based upon prior assessments, knowledge of the environment, and comparable application environments that they have assessed.

Figure 6.5 (*Continued*)



Governance, risk, compliance



CISO/ CSO/ ISO

Relevant stage(s): stage I, II, & VII
CSO and CISO roles are the figureheads to any security program, therefore, their influence across PASTA's threat modeling stages are always at an *Informed* level. Their roles are especially relevant however in potentially influencing what governance standards get promoted earlier in an SDLC process. Under the Define Business Objectives and Technology Scoping stages, the CSO/ CISO, and particularly the ISO have the ability to influence the adoption and use of technology standards as a form of blind threat modeling. In doing so, this allows the PASTA process to achieve yet another point of integration to legacy efforts in security governance. Similarly in Stage VII, these governance members carry an Informed role around residual risk issues that have been identified and presented back to a BU.



Compliance

Relevant stage(s): stage I, II, & VII
Risk centric threat modeling doesn't forego compliance risks. Those risks are real and can be preemptively addressed by factoring in regulatory requirements around data security, encryption, etc. earlier within the SDLC process. Similar to the influence that Security Governance leaders (CISO, CSO, ISO) have on security adoption, compliance professionals have the ability to relay impactful regulatory restraints that could affect BU level goals for a product or application. Therefore, Stage I and II are equally relevant to these threat modeling participants. Equally, their Informed roles during Stage VII provide Compliance group members with the ability to maintain awareness on what residual risk levels can equate to regulatory compliance risks, when mapped back to their respective control frameworks.



Risk assessors

Relevant stage(s): stage I & VII
Risk assessors and managers are involved in stage I: Define Business Objectives, where they may incorporate relevant prior risk findings in order to factor in an application risk profile that should be addressed earlier in the SDLC process. This risk profile depicts inherent risk issues that affect the security of the application, thereby possibly affecting the obtainment of defined business objectives for the application. Also involved in stage VII: Risk and Impact Analysis, risk professionals will help to quantify the residual risk issues that extend beyond the technical risk issues identified across the various PASTA stages.

Figure 6.6 GRC Cross Section of a Threat Modeling Team

for tasks deemed to be in their line of expertise, the threat modeler ultimately has to decide how those efforts are to be continued, if at all (e.g. by the threat modeler or another SME). Time delays as well as the criticality of fulfilling test cases in the areas associated with unavailable SMEs need to be considered against the fulfillment of the threat modeling objective.

Depth of experience and a comprehensive background in security operations and IT is reiterated by the aforementioned scenario where SMEs may not be always at hand. Since exploiting identified vulnerabilities is critical to the risk analysis in that it provides credibility to the probability coefficients within the risk equation, the threat modeler must elect how and when to proceed when a complete threat modeling team is not able to contribute, particularly in areas that improve the overall risk analysis. Devoid of this ability, the risk analysis under a risk-based approach to threat modeling is weakened, as is the risk message conveyed back to the business. Other scenarios where SMEs are absent from the threat modeling team or group may prove less damaging to risk analytics.

It should go without saying that there will be much smaller organizations that do not have the depth of resources that other larger organizations have to achieve these dynamic and synergistic teams. In such cases, the threat modeler must judiciously select and recruit a team that would work and not compromise the job functions of those individuals. The lack of resources across these operational areas should not dissuade the application threat modeling efforts from commencing. More information on how to apply application threat modeling for smaller organizations will be addressed at the end of this chapter.

In the previous figure (Cross Section of a Threat Modeling Team), organizational members (in the middle column) are either loosely or closely associated to defined groups (on the left). An example may be Information Security Officers (ISOs) that are part of GRC efforts on a day-to-day basis. These recruits to the threat modeling process provide additional expertise around specific subject areas at varying phases of the PASTA threat modeling methodology. Building upon this example, an ISO may provide invaluable information on the risk analysis of an application environment during the threat analysis or risk analysis phase. Given the ISO's interaction with the business unit sponsoring the application, he/she may have a strong knowledge of regulatory, customer, or vendor-based considerations that should be accounted for, whether they are technical or nontechnical. For example, vendor-based support that implies use of nonstandard technologies within the application domain may need to be articulated and addressed in the data flow diagramming efforts or application decomposition talks, where applicable. Conversely, in regard to the nontechnical realm, the ISO may raise relevant, regulatory issues around data privacy that limit the manner in which functional requirements are implemented during the design or requirements phases of the SDLC. This latter example is a slight departure from security-centric or software-centric approaches, however, inclusive to the goals of identifying various risk types in a risk-centric approach.

Regardless of the apparent dependency that the threat modeler has on the various SMEs that may be brought into the application threat modeling process, the threat modeler himself/herself must also be well informed of the topics brought forth by

their SMEs so that they do not simply appear as a facilitator for a process that is self-guided by a series of SMEs. This reiterates the need for a well-rounded and experienced security professional to take charge of threat modeling efforts. Every organization is different so while in some places this could be a security professional, it other places it may be the architect, a PM, or even a developer who has some security background. Given that PASTA fosters more of a collaborative approach, the focus is less on this "threat modeler" role than the interoperability of all related members doing their part across each stage.

Ultimately, the members recruited to support various phases and areas of the PASTA threat modeling methodology only reinforce varying principles that support the type of approach that was selected. For example, under a software-centric approach, the role of the business analyst during the requirements phase of the SDLC will vary compared to that of a risk- or asset-centric approach to threat modeling. The software-centric approach will primarily call for the business analysts' depiction of functional requirements around the software. This provides a bare bones approach for sustaining code quality focused objectives that encase continuity, scalability, and efficiency. Separately, the security-centric approach seeks for the protection of these aforementioned objectives from security threats that include privilege escalation, information leakage, impersonation attacks, and so on.

The asset- or risk-centric approach may demand more from the business analyst in terms of conveying information that extends beyond the functional requirements for the application. The threat modeler may question the business analyst about operational uses of the existing or intended application in order to further refine the context understanding around business impact. This in turn enhances the overall risk analysis. This information would be sought in addition to their analysis of articulating functional requirements for the application. Another example (under the risk-centric approach) may be the threat modeler's interest in understanding the human use of the application environment once it is deployed into production. The user base (as a pool of application actors) is important for the threat modeler to identify in order to determine who may ultimately exert abuse cases in the threat model. For both human and nonhuman actors, this allows the threat modeler to qualify risks related to collusion, data theft, or malware proliferation, rogue API requests, privilege escalation, injection-based attacks and much more. This risk analysis extends beyond the exercises of the software- and security-centric approaches. This does not translate to PASTA being a more comprehensive threat modeling methodology but one that is focused with a different end goal – residual risk mitigation.

Tools

In terms of leveraging a tool that acts like a centerpiece to the threat modeling activities, there are several. Since Microsoft's approach to threat modeling are already encompassed within the PASTA threat modeling methodology, many of their tools serve as an excellent reference and documentation artifact for fulfilling PASTA's stages III–VI (inclusive). A good resource for conducting security-centric-based approaches to application threat modeling is the Threat Analysis and Modeling

(TAM) by Microsoft. Beta version 3.0 was released in the summer of 2009 and is a good supporting solution to capture many of the threat modeling variables such as actors, permissions (privileges), assets, vulnerabilities, and more. A software side-dish for software-centric threat modeling efforts is also provided by Microsoft and is geared toward both software developers and security professionals. The Microsoft SDL Threat Modeling tool focuses more on design flaws in the software development process and depicts these flaws in both security and nonsecurity contexts. For more information around threat modeling efforts sponsored by Microsoft, please visit their threat modeling blog at http://blogs.msdn.com/b/threatmodeling. Although distinct, much of the steps presented by these threat modeling approaches are already performed in PASTA's stages III–VI, inclusive. The key difference is that PASTA's focus is around threat mitigation to components that introduces material business risk. This is one key reason for which PASTA's threat modeling methodology encompasses more than just developers or architects since other roles can even provide greater contextual understanding of how functional specifications serve a business goal, not to mention on the impact sustained by identified technical risks. MyAppSecurity's Threat Modeler is building greater functionality to support the PASTA framework and is a free and intuitive threat modeling solution that can be used to simply capture many of the inputs for each stage.

Process and People

Multiple processes are impacted and leveraged as part of any threat modeling methodology. It should be stated that by "process" we are referring to security or IT processes that are occasionally found across various organizations. This includes (but is not limited to) IT, Support Operations, key third-party vendors, Legal, Executive Management, Human Resources, Facilities management and more. Some of these processes have been reflected in the aforementioned diagrams. Security Governance, Security Assurance, Security Operations are just a few major subsets of Information Security programs that are commonly found across various companies today. Most organizations do not have these groups uniquely staffed and equipped in the nonenterprise space. In most cases, security is fortunate enough to have a figurehead such as a CISO. Given this reality, it is foolhardy to expect that a unique group or individual be devoted to threat modeling efforts. Not only is this costly, it proceeds to follow in the same footsteps where isolated security groups reach nothing more than an adversarial relationship with internal colleagues in IT, Development, and the BU.

As shown in recent illustrations, several processes are leveraged by each stage of the PASTA methodology. Previously referenced groups and their corresponding processes are not generally foreign to most large enterprises, although they may be absent, developing, or maturing within smaller organizations. In those cases, companies will have to decide whether they can simply proceed with implementing PASTA while developing or further maturing those areas that require additional resources, refinement of process/deliverables, and solutions. Additionally, the threat analysis

will also provide direction in terms of identifying which groups will be more important to leverage in both the short and long run. For example, a good sense that targeted attacks or even recon efforts have been taking place across business groups may automatically create a need to interact more with those groups. Signs of prior reconnaissance efforts around a guarded facility may warrant the need to include facilities management officials as part of the threat modeling activities for each stage.

A list of enterprise processes (focused primarily around security and technology) that heavily influence various stages of PASTA are referenced subsequently and correlated to each stage (see Table 6.1).

As shown in Table 6.1, a multitude of enterprise processes should be injected into the threat modeling process in order to sustain the integrity of the overall model. This will require various information inputs as well as generated outputs. Threat modeling using PASTA demonstrates the collaborative approach achieved across various enterprise resources. Although threat modeling is not something that every company may embark on, it should not be because of the lack of resources, since the threat modeling process should be measured and matured over time. Despite the fact that larger enterprises may have an advantage over smaller companies in terms of resources, smaller organizations are able to adopt and produce very powerful threat models simply via their quicker ability to mobilize people and decision making. During various consulting engagements, it has been very apparent which companies were threat modeling capable and which were not. In several instances, the smaller organizations performed application decomposition exercises, CRUD role and privilege assignments, identified attack sectors, and more. While they excelled in these areas, they had shortcomings in areas like governance, where larger organizations were a bit more mature. Smaller organizations may have the advantage of diving into stages III and IV (Application Decomposition and Threat Analysis, respectively) simply because the development teams are generally much smaller. Larger organizations may have tougher political hurdles to jump over within these stages as collaboration among development groups moves much slower due to the size of the application development group. Conversely, the governance groups of larger enterprise environments are generally more sophisticated in order to create a strong foundation of the PASTA steps that encompass stages I, II, and VII. This is largely because these larger groups have a more experienced and sophisticated process around Governance, Risk, and Compliance.

The purpose of Table 6.1 is to intersect and align various IT, Governance, and other enterprise-related areas with specific PASTA threat modeling methodology stages. The following section will perform a hypothetical walk-through of the various PASTA application threat modeling methodology stages in order to clearly define the steps and actions that should be taken, while simultaneously considering possible challenges and variants that a threat modeler or team may witness in their own respective environments. This next section will also provide detailed specifics on what deliverables need to be produced as artifacts or inputs to other phases across the PASTA methodology.

TABLE 6.1 Enterprise Process Mapping to PASTA Threat Modeling Methodology

Process	PASTA Stage Mapping	Reasoning
IT governance	Stage I (Define Objectives), Stage II (Technical Scope)	Business objectives need to understand what tech/security governance applies to supporting their business objectives. Additionally, maturity modeling can be applied as a way to allow each stage of the application modeling methodology to grow. BSIMM (Building Security-In Maturity Modeling), SAMM (Software Assurance Maturity Modeling), and OpenSAMM could be applied as part of this governance effort for stage.
Security governance	Stages I and II (Define Objectives and Technical Scope).	Same as aforementioned but in a security context of preserving the business objectives via confidentiality, integrity, and availability control measures.
Compliance	Stage I (Define Objectives). Neglecting regulatory issues may adversely impact the realization of business objectives, which have to be incorporated into the threat model's risk-based approach	Business needs to understand how regulatory factors may affect the functional design/requirements from business objectives.
Security awareness	All stages are affected by security awareness. Security lessons are informally introduced/ reiterated to threat modeling audience members	Each phase portrays lessons of security awareness, but acted out in a collaborative effort to secure the subject application environment.
Risk assessments (RA)	Stage I (Define Objectives), Stage II (Technical Scope), Stage VII (Risk and Impact Analysis)	RAs done on similar environments internally may create inherent risk profiles for the (a) overall suite of use cases for the app and (b) inherent risks associated with the types of technologies (software/hardware) to be used in fulfillment of business objectives and functional requirements. Risk assessments can also leverage completed threat models to bolster the subsequent risk analysis provided by future risk assessments of the same application environment.

Business impact assessments (BIAs)	Stage VII (Risk and Impact Analysis).	BIAs are enterprise deliverables produced in order to determine the financial and business impact of applications to the business. It helps to leverage this deliverable when creating a risk synopsis for the application environment.
Privacy impact analysis(es)	Stage I (Define Objectives)	Privacy impact assessments (PIAs) conducted against the application environment, prior models/version, or similar versions of the software architecture will ultimately help shape technical requirements and design countermeasures that should be in place to protect against threats related to data leakage.
Vulnerability assessments	Stage V (Vulnerability and Weakness Enumeration)	Vulnerabilities from common solutions can be paired with attack patterns as part of the attack tree build-out. False positives are excluded from the integrated analysis.
Static analysis	Stage V (Vulnerability and Weakness Enumeration)	Coding flaws and weaknesses in software design are detected as part of the subject application environment and labeled as nodes/branches of the attack tree that correlate to feasible attacks.
Dynamic application analysis	Stage V (Vulnerability and Weakness Enumeration)	Vulnerable responses from the application's interpreter are captured and aligned to branches on the attack tree as vulnerabilities that could be exploited as an attack.
Red team exercises/social engineering	Stage V (Vulnerability and Weakness Enumeration), Stage VI (Attack Modeling)	Supportive processes to the application environment could be compromised via social engineering techniques, thereby testing the "human factor" becomes just as important as defending the logical application/network testing.
Software/security architectural	Stage III (Application Decomposition), Stage V (Vulnerability and Weakness Enumeration)	Define application entry/exit points, identify application actors, software/hardware assets, information assets (configuration files, relational databases, flat files), data calls/responses (APIs), trust boundaries, system/software services, compiled libraries, utilized executables/binaries, data sources, technical (functional/security) requirements, and anything that sustains the application architecture, which may in turn be leveraged as an attack vector.

(*continued*)

TABLE 6.1 (*Continued*)

Process	PASTA Stage Mapping	Reasoning
Project management	All stages, however Stage I (Define Objectives) is key to defining strong project governance	Project management must encompass security objectives throughout the threat modeling methodology. One of the project objectives (for an asset-centric approach) is to identify residual risk for the application environment.
Incident management	Stage IV (Threat Analysis)	During the process of identifying possible threats, incident management may provide the threat modeling team with historical incident response events from aggregate infrastructure alerts or comparable environments in order to help define or substantiate a threat analysis.
Network/security operations	Stage IV (Threat Analysis)	Similar to Incident Management, NOCs/SOCs monitor various events across the network that could help substantiate the threat analysis.
Security partners/managed security	Stage IV (Threat Analysis, Stage V (Vulnerability and Weakness Enumeration), Stage VI (Attack Modeling)	Security vendors and managed security service providers can actually conduct various threat modeling methodology stages for organizations that have weak maturity levels with these stages. Security partners and managed security providers can manage attack-related libraries, vulnerabilities databases/findings, as well as help refine threat analysis with correlative analysis or monitored threats that are internally or externally managed by the environment.
Software development	Stage I (Define Objectives)	All stages of any given software development methodology have some degree of relationship to the PASTA threat modeling methodology. Specific to software development, stage I helps to ensure that development receives security requirements to adhere to when building out their application environment.
Quality assurance	Stage VI (Attack Modeling)	Security testing is delivered to the application using a robust attack library that can be applied against the newly released code build. Security tests are based on understood threats contained from the threat model.
System administration	Stage II (Technical Scope)	System administrators, or those who are charged with properly implementing a system build, will be able to leverage the technical security requirements revealed under stage II.

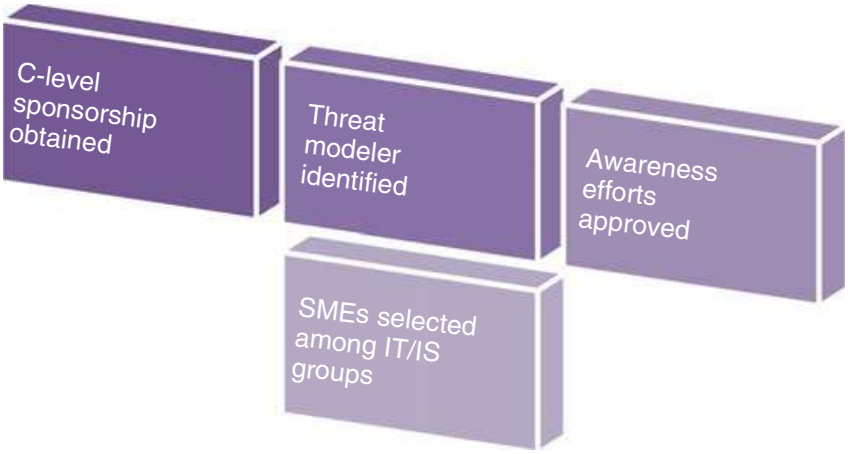


Figure 6.7 Givens Before PASTA Walk-Through

The following stages of the PASTA threat modeling methodology are depicted in the context of an application under development and governed by a Waterfall SDLC. The actions defined under each stage assume the following givens prior to formally commencing the methodology (Figure 6.7).

Expected Outputs from PASTA Across all of the stages to be covered in the subsequent sections, there will be many deliverables or artifacts produced from each of the stages produced from the PASTA methodology. Many of these artifacts are produced by some of the processes and resources previously mentioned as inputs. More detail on each type of artifact produced will be covered within each detailed stage of the application threat model methodology. Some of these artifacts are summarized in Table 6.2.

In the past few sections, we have looked at what inputs/outputs (in the form of artifacts or information sources) are needed for each stage of the PASTA threat modeling methodology. We have also looked at the necessary foundation of people, processes, and governance that should be in place for successful threat modeling to be sustainable. Specific to the people involved with PASTA, the following RACI (Responsible–Accountable–Consulted–Information) model has been provided to identify a generic, yet common list of enterprise roles that can be leveraged and customized by any organization looking to adopt PASTA as a threat modeling methodology. The proposed RACI diagram is found on the next page and addressed under each of the detailed stages that follow (Figure 6.8).

As shown in the aforementioned RACI model, most of the participants across the PASTA process are assigned a "Consulted" or "Informed" role. This helps to visualize how PASTA leverages existing roles in InfoSec that may carry out these functions. SMBs would most likely have the greatest challenges of not having all of these internal FTEs; however, accommodations can be made in order to customize PASTA's RACI model to be more adaptive to a reduced security workforce at an organization with varying resource restraints. The legend for the roles is on the right.

TABLE 6.2 Artifacts for Making PASTA

Stage	Inputs	Outputs
Define objectives	• Business Impact Analysis • Business Risk Impact Analysis • Business Requirements • Functional Requirements	• Description of the application functionality • List of business objectives • Business Impact Analysis ○ Compliance Reqs (PCI/FFIEC, etc.)
Define technical scope	• Platform Standards • Network Standards • Architectural Schematics/ Network Diagrams • Software Configuration Standards • Third-Party Security SLAs	• High level, end-to-end view of the application architecture • Protocol enumeration support by technical scope • Enumerated asset list, by criticality and technology dependency • List of all network devices/appliances
Application decomposition	• Architecture diagrams/design documents • Sequence diagrams • Use cases • Users, roles, and permissions associated with use cases • Logical diagrams of requests/responses within application scope	• Data Flow Diagrams (DFDs) of the application scope • Use and abuse cases ranked by criticality • User's access control matrix with roles, and permissions/trust levels on data and transactions • List of assets and APIs • Map of use cases to actors/assets

Threat analysis	• Generic list of threat agents and motives, internal Security incidents (SIRT) report • Fraud detection report • Secure incident event monitoring (SIEM) reports • Application and server logs (syslogs) • Threat intelligence reports, alerts and feeds	• Report of the most likely attack scenario-landscape that includes: ○ Documentation of threat agents and their targets ○ Documentation of threat agents and likely attacks vectors used ○ Documentation of observed security incidents-events that relate to likely threats and historical attacks ○ Reference to threat intelligence reports for likely attack scenarios
Vulnerability/Weakness mapping	• Library of threat trees mapping generic attacks to vulnerabilities • Documented attack scenarios (from threat analysis, stage IV) • Vulnerability reports for assets queried from the centralized vulnerability repository • Standards for vulnerability enumeration (MITRE CWE, CVE) • Standards for vulnerability scoring (CVSS, CWSS)	• Map of existing vulnerabilities to the nodes of a threat tree • Enumeration of these vulnerabilities using CVE-CWE Scoring of these using CVSS-CWSS • A list of attack scenarios, the applicable threats, and the vulnerabilities that these threats can exploit
Attack modeling	• Application technical scope-boundaries • Data flow diagrams • List of entry points and trust levels	• Application *attack surface* representation • *Attack tree* mapping to vulnerabilities and exploits Pen tester's list of possible attack paths to exploit the vulnerabilities and defined attack vectors.

(*continued*)

TABLE 6.2 (*Continued*)

Stage	Inputs	Outputs
	• List of communication channels • Attack libraries-patterns (e.g. MITRE CAPEC) • List of threats, attacks, and vulnerabilities to the application assets • Exploit Testing Results	
Risk and impact analysis	• Preliminary BIA of stage I • Application dependencies and technical boundaries identified at stage II • Granular application assets and components-data at risk identified at stage III • Threat Analysis Data provided at stage IV • Vulnerabilities mapping to threats and assets at stage V • Stage VI attacks simulated to cause exploits • Organization's information qualitative risk analysis models (e.g. NIST, OCTAVE, FAIR) and elements used (e.g. asset values) • Quantitative risk models • Mapping of attacks to countermeasures (e.g. OWASP TM) • Secure architecture guidelines and technical standards • Approved technical standards for countermeasures and technologies • Risk mitigation strategy guidelines (e.g. NIST)	• Detailed application *risk profile* that includes a description of the risks and the business impacts. • *Quantitative risk analysis* (e.g. ALE) for each vulnerability-exploit • *Qualitative risk analysis* for each vulnerability-exploit (e.g. likelihood × impact) • *Threat matrix* with threats, attacks, vulnerabilities, business impact, and the type countermeasure applied • Residual risk value to business after either (1) countermeasures are applied or (2) risks are compensated by current controls-measures • Risk mitigation strategies and cost-benefit analysis

APPLICATION THREAT MODELING ACTIVITIES per STAGE	MGT	PMO	BA	ARC	DEV	SYS	QA	SOC	VA	PT	RA	CMP	SA	TM
STAGE 1 - DEFINE BUSINESS OBJECTIVES	R/A	A	R/A	I	I	I	I	I	I	I	A	A	I	A
Define Business Requirements	A	I	R/A	I	I	I	I	I	I	I	I	I	I	A
Define Security/ Compliance Requirements	I	I	C	I	I	I	I	I	I	I	C	R/A	I	A
Define Business Impact	I	I	C	I	I	I	I	I	I	I	R/A	C	I	A
Define Risk Profile	I	I	R/A	I	I	I	I	I	I	I	I	I	I	A
STAGE 2 - TECHNICAL SCOPE	I	A	C	A	R/A	R/A	C	I	C	C	C	I	C	A
Enumerate Software Components	I	I	C	A	R/A	R/A	C	I	C	C	C	I	C	A
Identify Actors & Data Sinks/ Sources	I	I	C	C	R/A	C	C	I	C	C	C	I	C	A
Enumerate System-Level services	I	I	C	A	R/A	R/A	C	I	C	C	C	I	C	A
Enumerate 3rd Party infrastructures	I	I	C	A	R/A	R/A	C	I	C	C	C	I	C	A
Assert completeness of secure technical design	I	I	C	A	R/A	R/A	C	I	C	C	C	I	C	A
STAGE 3 - APPLICATION DECOMPOSITION	I	I	I	A	A	A	I	I	I	I	I	I	C	R/A
Enumerate all application use cases (ex: login, account update, delete users, etc.)	I	I	I	C	A	C	I	I	I	I	I	I	C	R/A
Perform Data Flow Diagram of Identified Components	I	I	I	A	C	C	I	I	I	I	I	I	C	R/A
Security functional analysis & the use of trust boundaries	I	I	I	C	A	A	I	I	I	I	I	I	C	A
STAGE 4 - THREAT ANALYSIS				I	I	I	I	R/A	C	C	C	C	C	R/A
Analyze the overall threat scenario				I	I	I	I	R/A	C	C	C	C	C	A
Gather Threat Intelligence from Internal Sources				I	I	I	I	R/A	C	C	C	C	C	A
Gather Threat Intelligence from External Sources				I	I	I	I	R/A	C	C	C	C	C	A
Update the threat libraries				I	I	I	I	C	C	C	C	I	C	R/A
Threat agents to asset mapping				I	I	I	I	R/A	C	C	C	C	C	A
Assign Probabilistic Values around Identified Threats				I	I	I	I	C	C	C	C	I	C	R/A

Figure 6.8 PASTA RACI Model

STAGE 5 - VUNERABILTIY ASSESSMENT				I	I	I	C	I	I	I	I	I	I	R/A
Review/Correlate Existing Vulnerability Data				I	I	I	I	I	R/A	I	I	I	I	A
Identify Weak Design Patterns in the Architecture				I	I	I	C	I	R/A	I	I	I	I	A
Map threats to vulnerabilities				I	I	I	C	I	R/A	I	I	I	I	A
Provide Context Risk Analysis based upon Threat-Vulnerability				I	I	I	I	I	C	I	I	I	I	R/A
Conduct Targeted Vulnerability Testing				I	I	I	I	R/A	C	C	C	C	C	A
STAGE 6 - ATTACK ENUMERATION							C	C	I	R/A	I	I	I	R/A
Analyze the attack scenarios							I	I	I	R/A	I	I	I	A
Update the attack library/vectors and the control framework							I	I	I	A	I	I	I	R/A
Identify the attack surface and enumerate the attack vectors							C	C	I	R/A	I	I	I	A
Assess the probability and impact of each attack scenario							I	I	I	C	I	I	I	R/A
Derive a set of cases to test existing countermeasures							I	I	I	C	I	I	I	R/A
STAGE 7 - COUNTERMEASURE DEVELOPMENT / RESIDUAL RISK ANALYSIS	C	C	C	C	C	C	I	I	I	I	C	C	C	R/A
Calculate the risk of each threat	I	I	I	I	I	I	I	I	I	I	C	I	C	R/A
Identify the countermeasures.	I	I	I	C	C	C	I	I	I	I	C	C	C	R/A
Calculate the residual risks	C	C	C	I	I	I	I	I	I	I	C	C	C	R/A
Recommend strategy to manage risks	C	C	C	I	I	I	I	I	I	I	C	C	C	R/A

Roles Legend

MGT	Management	DEV	Development	VA	Vuln Assessment	SA	Security Assurance
PMO	Project Mgt	SYS	SysAdmin	PT	Pen Tester	TM	Threat Modeler
BA	Business Analyst	QA	Quality Assurance	RA	Risk Assessor		
ARC	Architecture	SOC	Security Operations	CO	Compliance Officer		

RACI Legend

R	Responsible
A	Accountable
C	Consulted (2 way)
I	Informed (1 way)

Figure 6.8 (*Continued*)